

■ AWS IAM

Interview Preparation Guide

Hinglish Edition | DevOps/Cloud Engineer ke liye | HCLTech & Beyond

Table of Contents

1. Quick Revision Notes
2. IAM Policy Deep Dive
3. Password Policy & MFA
4. Access Keys, CLI & SDK
5. IAM Roles
6. IAM Security Tools
7. Interview Q&A; — Standard
8. Scenario-Based Questions
9. Hands-On Tasks
10. Quick Cheat Sheet

1. QUICK REVISION NOTES

IAM Kya Hai?

- **IAM = Identity and Access Management**
- Ye ek **Global Service** hai — region-specific nahi hota
- Har AWS account ke saath automatically available hota hai

Core Concepts — 5 Minute Mein Yaad Karo

Concept	Simple Definition
Root Account	Account create hone par banta hai. Use mat karo, share bilkul mat karo
User	Ek real person ya application jo organisation mein hai
Group	Users ka collection. Groups ke andar groups nahi hote
Policy	JSON document jo batata hai — kaun kya kar sakta hai

Role	AWS Services ke liye permission (users ke liye nahi, services ke liye)
------	--

3 Golden Rules — Interview Mein Zaroor Aata Hai

- **Root account** ko daily use mat karo
- **Least Privilege Principle** — jitni zaroorat ho utni hi permission do, zyada nahi
- **Groups ko policies assign karo**, individual users ko nahi (best practice)

User & Group Rules

- User ka group mein hona **mandatory nahi** — bina group ke bhi reh sakta hai
- Ek user **multiple groups** mein ho sakta hai
- Group sirf **users** contain karta hai — dusre groups nahi

2. IAM POLICY DEEP DIVE

Policy Kya Hota Hai?

Users ya groups ko **JSON documents** assign hote hain jinhe **Policies** kehte hain. Ye policies define karti hain ki user ya group kya **kar sakta hai ya nahi** kar sakta.

IAM Policy Inheritance

```
Developer Group (EC2 Full Access)
  Alice  EC2 Full Access (group se mili)
  Bob    EC2 Full Access (group se mili)

Tester Group (S3 Full Access)
  Charlie S3 Full Access
  Bob     Bob dono groups mein hai = EC2 + S3 Access

Inline Policy (Directly on User)
  David  sirf uski apni policy hai, kisi group mein nahi
```

Policy Structure — JAROOR Yaad Rakho

```
{
  "Version": "2012-10-17",
  "Id": "S3-Account-Permissions",
  "Statement": [
    {
      "Sid": "1",
      "Effect": "Allow",
      "Principal": { "AWS": ["arn:aws:iam::123456789:root"] },
      "Action": ["s3:GetObject", "s3:PutObject"],
      "Resource": ["arn:aws:s3:::mybucket/*"]
    }
  ]
}
```

Policy ke 6 Elements — Statement ke andar

Element	Kya Hai	Example
Sid	Statement ka ID (optional)	"1"
Effect	Allow ya Deny	"Allow"
Principal	Kaun? — User/Role/Account	arn:aws:iam::123:root
Action	Kya action allow/deny hai	s3:GetObject
Resource	Kaunsi resource pe apply hoga	arn:aws:s3:::mybucket/*
Condition	Kab lagega ye policy	MFA required, specific IP

Interview Tip: Version '2012-10-17' ALWAYS same rehta hai — ye policy language version hai, date nahi

3. PASSWORD POLICY & MFA

Password Policy — AWS Mein 5 Chize Set Kar Sakte Ho

- **Minimum length** set karo (8, 12, 16 characters)
- **Character types** require karo: Uppercase (A-Z), Lowercase (a-z), Numbers, Special chars (!@#%)
- **Users ko apna password change** karne do
- **Password expiry** — X days baad change karna padega
- **Password reuse** rokna — purana password dobara use nahi kar sakte

MFA = Password jo tum jaante ho + Security device jo tum rakhte ho

AWS Mein MFA Device Options

Type	Example	Kaise Kaam Karta Hai
------	---------	----------------------

Virtual MFA	Google Authenticator, Authy	Phone app se OTP. Authy: multiple tokens ek device pe
U2F Security Key	YubiKey by Yubico (3rd party)	Physical USB key
Hardware MFA	Hardware token device	Physical device from AWS

4. ACCESS KEYS, CLI & SDK

AWS Access Karne ke 3 Tarike

Method	Kaise Protect Hota Hai	Use Case
Management Console	Password + MFA	Browser se visual work
CLI (Command Line)	Access Keys	Terminal/Script automation
SDK	Access Keys	Application code mein

Access Keys — Important Rules

- Access keys **AWS Console se generate** hote hain
- Users apni **khud ki access keys manage** karte hain
- Access keys **secret hain** — password ki tarah. **Kabhi share mat karo**
- **Access Key ID** = Username ki tarah
- **Secret Access Key** = Password ki tarah

AWS CLI Setup Steps

```
# Step 1: AWS CLI install karo (documentation se)
# Step 2: AWS Configure run karo
aws configure

# Ye 3 cheeze maangega:
# 1. AWS Access Key ID
# 2. AWS Secret Access Key
# 3. Default Region (e.g., ap-south-1)
```

Access Key Kahan Se Milega?

```
IAM --> IAM Users --> Apna Username click karo
--> Security Credentials tab
--> Create Access Key
--> Save karo (ek hi baar dikhega!)
```

AWS SDK Kya Hai?

- **AWS Software Development Kit** — Language-specific APIs (libraries ka set)

- Enable karta hai **programmatically** AWS services access aur manage karna
- Application ke **andar embedded** hota hai
- **Supports all languages**: Python (boto3), JavaScript, Java, .NET, Go, etc.

AWS CloudShell

Feature	Detail
Type	Browser-based pre-authenticated terminal
Setup	No local setup needed — runs in browser
Tools	Pre-installed tools available
Cost	Free to use
Access	AWS Console → Top navigation bar → CloudShell icon

5. IAM ROLES

IAM Roles Kya Hain?

- Kuch AWS services ko **tumhare behalf pe actions perform** karne hoti hain
- Uske liye hum **IAM Roles** use karte hain
- Roles **Services ke liye hote hain** — users ke liye nahi

Common Roles — Har Interview Mein Puchhe Jaate Hain

Role	Kab Use Hota Hai
EC2 Instance Role	EC2 ko S3/DynamoDB access dena ho
Lambda Function Role	Lambda function ko AWS services access dene ke liye
CloudWatch/CloudFormation Role	Monitoring aur infrastructure automation ke liye

IAM Role vs Access Keys — Interview Ka Sabse Important Question!

IAM Role (Better)	Access Keys (Risky)
More Secure	Manual management
Temporary credentials (auto-expire)	Long-lived credentials
Auto rotation	Manual rotation
No hardcoded secrets	Secrets code mein aa jaate hain
Easy management	Revocation mushkil

EC2 Ko S3 Ka Access Kaise Doge? (Step-by-Step)

Step 1: IAM --> Role create karo (EC2 ke liye)
Step 2: S3 policy attach karo us role pe
Step 3: Role ko EC2 instance pe attach karo
Step 4: EC2 automatically temp credentials use karta hai — no keys needed!

6. IAM SECURITY TOOLS

Tool	Level	Kya Dikhata Hai	Kab Use Karo
IAM Credentials Report	Account	Saare users aur credentials ka status	Audit: kaun MFA use kar raha, kaun nahi
IAM Access Advisor	User	Permission grant & last access	Least privilege enforce karne ke liye — unused permissions remove karo

7. INTERVIEW Q&A; — STANDARD

Basic Level

Q1: IAM kya hai aur ye Global service kyun hai?

IAM (Identity and Access Management) AWS ka service hai jo users, groups, aur permissions manage karta hai. Ye Global service hai kyunki ek baar banao aur sab regions mein kaam karta hai — alag-alag region select nahi karna padta.

Q2: Root account use karna risky kyun hai?

Root account ke paas unlimited permissions hoti hain — billing changes, account deletion, sab kuch. Agar ye compromise ho jaye toh poora account khatam. Isliye daily tasks ke liye hum IAM users banate hain aur root ko sirf initial setup ke liye rakhte hain.

Q3: Group ke andar group kyun nahi hota AWS IAM mein?

AWS IAM ka design deliberately flat hai — groups sirf users ko contain karte hain, nested groups nahi. Agar groups ke andar groups hote toh permission inheritance complex aur unpredictable ho jaati. Ye deliberate design choice hai simplicity ke liye.

Q4: Least Privilege Principle explain karo.

Simple hai — user ko sirf utni hi permission do jitni uske kaam ke liye zaroor hai. Zyada permission dene se security risk badhta hai. Example: Developer ko S3 read access chahiye toh sirf s3:GetObject do, s3:* nahi.

Q5: MFA mandatory hai IAM mein?

Default se mandatory nahi hai, lekin strongly recommended hai — especially root account aur admin users ke liye. Password policy se aap MFA enforce kar sakte ho.

Intermediate Level

Q6: Managed Policy vs Inline Policy mein difference?

Managed Policy: Ek standalone policy jo multiple users/groups/roles pe attach ho sakti hai. Inline Policy: Directly user/group/role ke andar embedded hoti hai, reusable nahi. Best practice: Managed policies use karo kyunki reusable aur maintainable hain.

Q7: Policy evaluation order kya hai jab ek user ke multiple policies hain?

AWS follows: Explicit Deny > Explicit Allow > Default Deny. Matlab agar kisi bhi policy mein Deny hai toh baat khatam — chahe 10 Allow bhi hon.

Q8: IAM Role assume karna kya hota hai?

Jab koi user ya service ek Role ko temporarily 'assume' karta hai — matlab us role ki permissions temporarily apne upar le leta hai. STS (Security Token Service) temporary credentials issue karta hai jaise ek security pass — limited time ke liye.

Q9: Service Control Policies (SCP) IAM policies se kaise alag hain?

SCPs AWS Organizations mein use hote hain — poore accounts ya OUs pe apply hote hain. IAM policies individual users/groups/roles pe. SCP maximum permission boundary set karta hai — IAM policy us boundary ke andar hi kaam kar sakti hai.

Q10: ARN kya hota hai?

Amazon Resource Name — AWS ka unique identifier har resource ke liye. Format: `arn:aws:service:region:account-id:resource`. Example: `arn:aws:s3:::mybucket` — S3 bucket ka ARN (region aur account ID nahi hota S3 mein kyunki global hai).

8. SCENARIO-BASED QUESTIONS

Scenario 1: Developer Ne Accidentally S3 Delete Kar Diya

Situation: Ek junior developer ne production S3 bucket delete kar diya. Tum DevOps engineer ho — kya karte?

IMMEDIATE RESPONSE:

1. Versioning ON tha? --> S3 versioning se objects restore karo
2. Backup policy check karo
3. Developer ke IAM permissions audit karo

ROOT CAUSE PREVENTION:

- Developer ko `s3:DeleteBucket` permission kyun thi? Least Privilege violate hua
- Fix: Developer group se Delete permissions remove karo
- Add SCP at org level: Production accounts mein S3 deletion block karo
- Enable MFA Delete on S3 buckets

Scenario 2: Naya Team Join Hua — Onboarding Kaise Karoge?

Situation: 5 developers aur 2 testers aaye hain. IAM setup karo.

```
Step 1: Groups banao
- "developers" group --> EC2, CodeCommit, CodeDeploy access
- "testers" group --> S3 read, CloudWatch logs access

Step 2: Managed Policies create/attach karo groups pe (NOT individual users!)

Step 3: IAM Users create karo
- Fill form --> group assign karo --> create

Step 4: MFA enforce karo
- Password policy set karo
- MFA mandatory karo console access ke liye

Step 5: Credentials report generate karo after 1 week
```

Scenario 3: EC2 Ko RDS Ka Access Chahiye

Situation: Tumhara EC2 instance Python application run kar raha hai jisko RDS access chahiye. Kya approach loge?

```
WRONG APPROACH:
DO NOT hardcode credentials in code:
aws_access_key = "AKIAIOSFODNN7EXAMPLE" # NEVER DO THIS!

CORRECT APPROACH:
1. IAM Role create karo: "EC2-RDS-Access-Role"
2. Policy attach karo: AmazonRDSFullAccess (ya specific read/write)
3. EC2 instance mein role attach karo
4. Application automatically instance metadata se credentials leta hai
5. No hardcoded keys, auto-rotating credentials!
```

Scenario 4: Audit Request — Prove Least Privilege Follow Ho Raha Hai

Situation: Security audit mein tumhe prove karna hai ki unused permissions hain ya nahi.

```
1. IAM Access Advisor use karo
- Har user ke liye check karo: konsi services 90 days mein access hui
- Jo services access nahi hui --> unki permissions remove karo

2. IAM Credentials Report generate karo
- Account-level: kaun active, kaun MFA use kar raha, password age

3. CloudTrail logs review karo
- Actual API calls dekho — kaunse actions actually hue

4. Report present karo management ko with evidence
```


Scenario 5: Contractor Ko Temporary Access Dena Hai

Situation: Ek 3rd party contractor ko 1 mahine ke liye S3 bucket access chahiye.

Option 1: IAM User with expiry policy

- IAM user banao + Time-based condition policy lagao
- Account disable karo end date pe

Option 2: IAM Role with cross-account access (BEST PRACTICE)

- Contractor apne AWS account se role assume karega
- Temporary credentials milti hain
- Access automatically expire hoti hai

Option 3: AWS STS AssumeRole

- Time-limited tokens (1 hour to 12 hours)
- No permanent credentials

9. HANDS-ON TASKS

Task 1 — Beginner: Basic IAM Setup

1. AWS Console --> IAM
2. "developers" group banao
3. AmazonEC2ReadOnlyAccess policy attach karo group ko
4. New IAM user banao: "dev-user-01"
5. User ko developers group mein add karo
6. Console access enable karo (custom password)
7. MFA setup karo Google Authenticator se
8. Login test karo dev-user se
9. Verify: EC2 list hoga, lekin terminate nahi hoga

Task 2 — Intermediate: Custom Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowS3ReadOnly",
      "Effect": "Allow",
      "Action": ["s3:GetObject", "s3:ListBucket"],
      "Resource": ["arn:aws:s3::my-project-bucket",
                  "arn:aws:s3::my-project-bucket/*"]
    },
    {
      "Sid": "DenyDelete",
      "Effect": "Deny",
      "Action": "s3:DeleteObject",
      "Resource": "arn:aws:s3::my-project-bucket/*"
    }
  ]
}
```

-- Save as "ProjectS3ReadOnly" -- Attach to test user
-- Verify: GetObject kaam kare, Delete fail ho

Task 3 — Intermediate: EC2 Role

1. IAM --> Roles --> Create Role
2. Trusted Entity: AWS Service --> EC2
3. Policy attach: AmazonS3ReadOnlyAccess
4. Role naam: "EC2-S3-Read-Role"
5. EC2 instance launch karo (free tier t2.micro)
6. IAM Role attach karo instance pe
7. SSH karo EC2 mein
8. Run: `aws s3 ls` (no credentials needed!)
9. Verify: S3 list hoga, delete fail hoga

Task 4 — Advanced: Security Audit

1. IAM --> Credential Report --> Download (CSV)
2. Excel mein open karo, identify karo:
 - Users jinhone 90+ din se login nahi kiya
 - Users jinka MFA enabled nahi
 - Users ke paas unrotated access keys
3. Access Advisor check karo har user ke liye
4. Unused permissions list karo
5. Action plan banao: kaun si permissions remove karni

Task 5 — AWS CLI Practice

```
# IAM users list karo
aws iam list-users

# User ki policies dekho
aws iam list-attached-user-policies --user-name dev-user-01

# User ko group mein add karo
aws iam add-user-to-group --user-name dev-user-01 --group-name developers

# Password policy set karo
aws iam update-account-password-policy \
  --minimum-password-length 12 \
  --require-uppercase-characters \
  --require-numbers --require-symbols \
  --allow-users-to-change-password \
  --max-password-age 90

# Credentials report generate + download
aws iam generate-credential-report
aws iam get-credential-report --query Content --output text | base64 -d
```

10. QUICK CHEAT SHEET

IAM = Global Service (no region needed)
Root = Dangerous, Use Minimum (no daily use!)
Groups = Users ka Collection (NO nested groups)
Policies = JSON documents, define permissions
Roles = AWS Services ke liye (not users)
MFA = Password + Physical/Virtual Device
Access Keys = CLI/SDK ke liye (NEVER hardcode!)
CloudShell = Browser-based, free, no setup
Least Priv. = Minimum permissions, always

Policy Priority: Explicit DENY > ALLOW > Implicit DENY

Console --> Password + MFA
CLI --> aws configure (Access Key + Secret Key)
SDK --> Code mein (use IAM Role instead of keys!)

Virtual MFA = Google Authenticator / Authy (phone)
U2F = YubiKey (physical USB key)

EC2 Role Setup: Role Create --> S3 Policy --> Attach to EC2
EC2 automatically uses temp credentials (no keys!)

Credentials Report --> Account Level --> CSV export
Access Advisor --> User Level --> Last accessed service

TOP 10 INTERVIEW QUESTIONS — Final Revision

- 1. Root account vs IAM user difference?
- 2. Least privilege principle kya hai? Example do.
- 3. IAM Policy ka JSON structure explain karo (6 elements)?
- 4. IAM Role aur Access Keys mein konsa better hai aur kyun?
- 5. MFA kya hai? AWS mein kaun kaun se options hain?
- 6. EC2 ko S3 access kaise doge? (Step-by-step)
- 7. Explicit Deny vs Implicit Deny difference?
- 8. IAM Credentials Report aur Access Advisor mein difference?
- 9. Group ke andar group kyun nahi hota?
- 10. CloudShell kya hai aur kab use karte hain?

All the best Pranav! Interview crack ho jayega! ■